Vendor and Third-Party Management Policy

Document control	
Company	LogistiComp S.A.
Document ID	LC-POL-009
Version	1.3
Classification	Internal – may be shared with customers under NDA
Owner	Chief Information Security Officer (CISO)
Approved by	Information Security Steering Committee (ISSC)
Effective date	15 January 2026
Next review	January 2027

1. Purpose

LogistiComp relies on suppliers to deliver LogistiComp WMS, most importantly for cloud hosting and security monitoring. This policy defines how the Company selects, contracts, monitors and offboards suppliers, so that the risks they bring to LogistiComp and its customers are identified and managed. It implements Section 14 of the Information Security Policy (LC-POL-001).

2. Scope

This policy applies to all third parties that:

- access LogistiComp information or systems;
- process customer data or other personal data on the Company's behalf (sub-processors);
- provide services that LogistiComp WMS depends on; or
- provide software-as-a-service tools used by LogistiComp personnel.

This includes contractors and consultants who work with LogistiComp systems.

3. Roles and Responsibilities

- **CISO:** owns this policy, defines the security requirements for suppliers and reviews security assessments.
- **Chief Financial Officer (CFO):** responsible for the procurement process and for making sure that contracts are signed before any service starts.
- **Data Protection Officer (DPO):** reviews the data protection terms with suppliers that process personal data and maintains the list of sub-processors (LC-POL-006,

Section 7).

- **Vendor owner:** every supplier has a named vendor owner in the business, who is responsible for the relationship, for monitoring the service and for starting the reviews required by this policy.

4. Vendor Inventory

The CISO maintains an inventory of all suppliers within scope. For each supplier, the inventory records the service provided, the vendor owner, the risk tier, the data the supplier can access, the location of processing, and the dates of the last and next review.

5. Risk Tiers

Every supplier is assigned a risk tier before the contract is signed:

Tier	Criteria	Examples	Security review
Tier 1 – Critical	Processes customer data, or a failure of the supplier would stop LogistiComp WMS	Cloud hosting provider, managed SOC provider, support ticketing provider	Full assessment before contracting; **reviewed annually**
Tier 2 – High	Has access to Confidential information or to corporate systems, but not to customer data	HR and payroll service, CRM system	Full assessment before contracting; reviewed every 2 years
Tier 3 – Low	No access to LogistiComp data or systems	Office supplies, catering	Basic checks when the supplier is onboarded only

6. Due Diligence Before Contracting

For Tier 1 and Tier 2 suppliers, the due diligence includes:

- a security questionnaire, reviewed by the security team;
- evidence of independent assurance, normally a valid ISO/IEC 27001 certificate or a SOC 2 Type II report, which the security team reviews, including any exceptions it reports;
- for suppliers that process personal data, a review of their data protection practices by the DPO;
- confirmation of where data will be stored and processed. Suppliers that process customer data must store and process it **only within the European Union**;
- for Tier 1 suppliers, a check of the supplier's financial stability and of its own business continuity arrangements.

Identified risks are recorded in the risk register (LC-POL-001, Section 6). A supplier with unacceptable risks may only be contracted with the approval of the ISSC.

7. Contract Requirements

Contracts with Tier 1 and Tier 2 suppliers must include:

- confidentiality obligations;
- the security measures the supplier must maintain;
- an obligation to notify LogistiComp of any security incident affecting LogistiComp data **within 24 hours** of the supplier becoming aware of it;
- LogistiComp's right to audit the supplier, or to receive independent audit reports instead;
- restrictions on subcontracting: the supplier may not pass LogistiComp data to its own subcontractors without LogistiComp's prior written approval;
- the return and deletion of LogistiComp data at the end of the contract;
- for suppliers that process personal data, a data processing agreement that meets Article 28 of the GDPR.

The 24-hour notification period allows LogistiComp to meet its own commitment to notify affected customers within 48 hours (LC-POL-003, Section 9).

8. Supplier Access to LogistiComp Systems

Supplier personnel who need access to LogistiComp systems receive named personal accounts and must follow the Access Control and Password Policy (LC-POL-002), including the use of multi-factor authentication. Access is limited to what the supplier needs, is granted for a defined period, and is included in the regular access reviews. Shared supplier accounts are not permitted.

9. Ongoing Monitoring

- Tier 1 suppliers are reviewed annually, and Tier 2 suppliers every two years. Each review checks that certificates and audit reports are still valid, that the service has met its agreed service levels, and whether any security incidents have occurred.
- The security team follows public security advisories and news about Tier 1 suppliers, and starts an immediate review if a supplier suffers a significant security incident.
- Significant changes in a supplier's service, ownership or location of processing trigger a new assessment.

10. Contingency and Exit Planning

For every Tier 1 supplier, LogistiComp maintains a documented exit plan, which describes how the service would be replaced or brought in-house if the supplier failed or the relationship ended. Exit plans are reviewed annually together with the supplier review, and are part of the disaster recovery scenarios in LC-POL-004.

11. Offboarding

When a contract ends, the vendor owner makes sure that:

- all supplier access to LogistiComp systems is revoked on the last day of the contract;
- LogistiComp data is returned or deleted, and the supplier confirms deletion in writing within 30 days;
- Company equipment is returned;
- the vendor inventory and, where relevant, the list of sub-processors are updated.

12. Review

This policy is reviewed at least annually by the CISO and approved by the ISSC.